

ETHICAL HACKING COMPLETE NOTES

Easy Language • Real-Life Examples • Important Topics Highlighted

★ Red star = Important Topic (read carefully, exam / interview favorite)

MMOC TEACH
MADE BY PRAVENDRA

INDEX

- ★ **1. Introduction to Ethical Hacking**
- 2. Types of Hackers
- ★ **3. Phases of Ethical Hacking (Hacking Methodology)**
- ★ **4. Footprinting and Reconnaissance**
- ★ **5. Scanning Networks**
- 6. Enumeration
- ★ **7. Vulnerability Assessment**
- ★ **8. Penetration Testing**
- 9. System Hacking (Password Cracking & Privilege Escalation)
- 10. Malware Threats in Hacking
- 11. Sniffing (Packet Sniffing)
- ★ **12. Social Engineering**
- 13. Denial of Service (DoS) and DDoS Attacks
- 14. Session Hijacking
- 15. Hacking Web Servers
- ★ **16. Hacking Web Applications (SQL Injection & XSS)**
- 17. Wireless Network Hacking
- 18. Cryptography for Ethical Hackers
- 19. Evading Firewalls, IDS, and Honeypots
- 20. Mobile and Cloud Platform Hacking
- ★ **21. Tools Used in Ethical Hacking**
- ★ **22. Report Writing and Legal Aspects**

★ 1. Introduction to Ethical Hacking [IMPORTANT TOPIC]

Explanation:

Ethical Hacking means legally breaking into computers and networks to test their security, with the FULL PERMISSION of the owner. The goal is to find weaknesses before a real criminal hacker (Black Hat) finds and misuses them.

An ethical hacker thinks and acts like an attacker, but reports every weakness found so it can be fixed. This is why ethical hacking is also called 'White Hat hacking' or 'Penetration Testing'.

Key Points:

- Always done with written permission from the system owner.
- Goal is to improve security, not to cause damage.
- Follows a proper legal agreement (called 'scope of work') before starting.
- Ends with a detailed report of all weaknesses found.

Example:

A bank hires an ethical hacker to try breaking into its mobile app. The hacker finds a weakness in the login page and reports it, so the bank can fix it before a real criminal discovers it.

Real-Life Example:

Big tech companies like Google, Facebook, and Microsoft run official 'Bug Bounty' programs, paying ethical hackers money for every real security flaw they responsibly report.

 *Note: Hacking a system WITHOUT permission — even 'just to test it' — is illegal, even if your intentions are good.*

2. Types of Hackers

Explanation:

Hackers are grouped by their intentions and whether they have permission to test a system.

Key Points:

- White Hat -> ethical hackers, hack legally with permission to improve security.
- Black Hat -> criminal hackers, hack illegally to steal or damage.
- Grey Hat -> hack without permission, but usually without harmful intent (a mix of both).
- Script Kiddie -> beginner who uses ready-made hacking tools without deeply understanding them.

Example:

A White Hat hacker is hired by a company. A Black Hat hacker breaks into the same company's server illegally to steal customer data.

Real-Life Example:

Kevin Mitnick, once a famous Black Hat hacker, later became a well-respected White Hat security consultant and author.

★ 3. Phases of Ethical Hacking (Hacking Methodology) [IMPORTANT TOPIC]

Explanation:

Ethical hacking is not random — it follows a structured, step-by-step process called the hacking life cycle. Every professional penetration test follows these same basic phases.

Key Points:

- 1. Reconnaissance -> gathering information about the target.
- 2. Scanning -> finding open doors (ports, weaknesses) in the system.
- 3. Gaining Access -> actually breaking into the system using a found weakness.
- 4. Maintaining Access -> staying inside without being noticed (to test how deep an attacker could go).
- 5. Covering Tracks -> a real hacker hides evidence; an ethical hacker instead documents everything for the report.

Example:

An ethical hacker first researches a company's website (Reconnaissance), scans it for open ports (Scanning), finds a weak login form and gets in (Gaining Access), checks what else could be accessed (Maintaining Access), then writes a full report (instead of Covering Tracks).

Real-Life Example:

This exact 5-phase structure is taught in the official CEH (Certified Ethical Hacker) certification course.

★ 4. Footprinting and Reconnaissance [IMPORTANT TOPIC]

Explanation:

Footprinting (also called Reconnaissance) is the very FIRST step of hacking — collecting as much public information as possible about a target before attacking it, such as domain names, employee names, IP addresses, and technologies used.

Key Points:

- Passive Reconnaissance -> gathering info WITHOUT directly contacting the target (example: searching Google, LinkedIn, WHOIS records).
- Active Reconnaissance -> gathering info by DIRECTLY interacting with the target (example: pinging their server).

Example:

Before attacking a company, a hacker searches its website, checks employee names on LinkedIn, and looks up the company's domain registration details using a WHOIS search — all without ever touching the company's actual systems.

Real-Life Example:

Many real attacks start with information found in old job postings, which sometimes accidentally reveal what software and tools a company uses internally.

 *Note: The more information a hacker gathers here, the more precisely targeted (and dangerous) the later attack can be.*

★ 5. Scanning Networks [IMPORTANT TOPIC]

Explanation:

After gathering information, the next step is Scanning — actively probing the target's network to find live computers, open ports, and running services. This tells the hacker exactly where a possible weak entry point might be.

Key Points:

- Port Scanning -> checking which 'doors' (ports) on a computer are open and listening.
- Network Scanning -> finding which computers on a network are active.
- Vulnerability Scanning -> checking for known weaknesses in the services found.

Example:

A hacker uses a tool to scan a server and discovers that Port 21 (FTP) is open and running an old, outdated version of software — a possible easy entry point.

Real-Life Example:

Nmap is the world's most widely used tool for network and port scanning, used by both ethical hackers and security teams.

6. Enumeration

Explanation:

Enumeration goes one level deeper than scanning — actively extracting detailed information from an already-discovered target, such as usernames, shared folders, or software version numbers, which can later be used to break in.

Example:

After finding an open port running a file-sharing service, a hacker uses enumeration to list all the shared folder names and even valid usernames on that system.

Real-Life Example:

Enumeration is often how attackers first learn valid employee usernames, which are then used later in password-guessing attacks.

★ 7. Vulnerability Assessment *[IMPORTANT TOPIC]*

Explanation:

A Vulnerability Assessment is the process of scanning a system to find and LIST known security weaknesses — but without actually exploiting (breaking into) them. It answers the question: 'What weaknesses exist here?'

Example:

A vulnerability scan of a company's website reveals that it is running an old version of software with 5 known, published security flaws.

Real-Life Example:

Tools like Nessus and OpenVAS are widely used by companies to regularly scan their own systems for known vulnerabilities.

 *Note: A Vulnerability Assessment only FINDS weaknesses; a Penetration Test actually TRIES to exploit them to prove real risk.*

★ 8. Penetration Testing [IMPORTANT TOPIC]

Explanation:

Penetration Testing (or 'pen testing') goes further than a vulnerability assessment — it actively tries to EXPLOIT the found weaknesses, just like a real attacker would, to prove exactly how much damage is truly possible.

Key Points:

- Black Box Testing -> tester has NO prior information about the system (like a real outside attacker).
- White Box Testing -> tester is given FULL information (like source code, network diagrams).
- Grey Box Testing -> tester is given PARTIAL information (a mix of both).

Example:

A pen tester finds a weak login form during assessment, then actually attempts to log in using that weakness to prove real customer data could be accessed.

Real-Life Example:

Companies often hire outside pen testing firms once or twice a year as a standard part of their security routine.

9. System Hacking (Password Cracking & Privilege Escalation)

Explanation:

System Hacking means actually gaining unauthorized access to a computer, often by cracking passwords, then trying to get MORE control than originally allowed — this second step is called Privilege Escalation (going from a normal user to an 'admin' account).

Example:

A hacker gains access to a normal employee account using a stolen password, then finds a system flaw that lets them escalate to full administrator control over the whole computer.

Real-Life Example:

Privilege escalation is one of the most dangerous parts of an attack, because it can turn a small breach into complete control of a system.

10. Malware Threats in Hacking

Explanation:

Ethical hackers must also understand malware (harmful software) — like viruses, worms, Trojans, and ransomware — since attackers often use these tools to gain or keep access to a hacked system.

Example:

An attacker installs a Trojan on a hacked computer, disguised as a normal update file, so they can secretly control it again later even after the original weakness is fixed.

Real-Life Example:

Malware analysis, where ethical hackers safely study how a piece of malware works, is a specialized career field within cyber security.

11. Sniffing (Packet Sniffing)

Explanation:

Sniffing means secretly capturing and reading data as it travels across a network, using a tool called a 'packet sniffer'. If the data is not encrypted, a hacker can directly read sensitive information like passwords.

Example:

An attacker on the same office Wi-Fi uses a sniffing tool to capture unencrypted login data being sent by a coworker's computer.

Real-Life Example:

Wireshark is the most well-known network sniffing tool, used by both ethical hackers and network engineers.

 *Note: Using HTTPS and encrypted connections is the main defense against sniffing attacks.*

★ 12. Social Engineering [IMPORTANT TOPIC]

Explanation:

Social engineering means tricking a PERSON — rather than hacking a computer directly — into revealing confidential information or granting access, usually by pretending to be someone trustworthy.

Key Points:

- Phishing -> fake emails or messages that trick people into clicking malicious links.
- Pretexting -> creating a believable fake situation to gain someone's trust.
- Baiting -> leaving something tempting (like a USB drive labeled 'Salary List') for a victim to plug in.

Example:

A hacker calls an employee, pretending to be from 'IT Support', and convinces them to reveal their login password to 'fix an urgent issue'.

Real-Life Example:

Studies consistently show that most successful cyber attacks start with a human mistake, not a technical flaw — which is why social engineering is tested in ethical hacking too.

13. Denial of Service (DoS) and DDoS Attacks

Explanation:

A Denial of Service attack floods a system with so much fake traffic that it becomes too slow or crashes, making it unavailable for real users. A DDoS (Distributed DoS) attack does this using MANY computers at once, making it much harder to stop.

Example:

An ethical hacker performs a controlled DoS test on a client's server (with permission) to check how much traffic it can handle before crashing.

Real-Life Example:

In 2016, a massive DDoS attack on a company called Dyn brought down major websites like Twitter and Netflix for hours.

14. Session Hijacking

Explanation:

Session hijacking means stealing an already-active login session from a real user, allowing the attacker to impersonate them WITHOUT even needing their password — often by stealing a 'session ID' or 'cookie'.

Example:

A hacker on public Wi-Fi intercepts a website's session cookie from another user's browser, then uses it to log into that person's account without ever knowing their password.

Real-Life Example:

This is one of the reasons websites now automatically log users out or regenerate session tokens after important actions like changing a password.

15. Hacking Web Servers

Explanation:

A web server hosts websites and web applications. Attackers target weaknesses in outdated server software, poor configuration, or exposed admin panels to take control of the entire server, not just one website.

Example:

A hacker finds that a web server's admin login page is publicly accessible and still uses the default, unchanged password — giving them full control of the server.

Real-Life Example:

Many real-world hacks happen not because of complex attacks, but simply because default settings and passwords were never changed.

★ 16. Hacking Web Applications (SQL Injection & XSS) [IMPORTANT TOPIC]

Explanation:

Web applications (like login forms, search boxes, and comment sections) are common attack targets. Two of the most famous web attacks are SQL Injection (tricking a database into leaking or changing data) and Cross-Site Scripting / XSS (injecting malicious code that runs in other users' browsers).

Example:

A hacker types special text into a login field to trick the website's database into logging them in without a real password (SQL Injection). Or, they post a hidden malicious script in a comment box that runs whenever someone else views that comment (XSS).

Real-Life Example:

SQL Injection and XSS regularly appear in the official OWASP Top 10 list of the most critical web application security risks.

 *Note: Ethical hackers test these exact attacks (with permission) to make sure a website properly checks and cleans all user input.*

17. Wireless Network Hacking

Explanation:

Wireless (Wi-Fi) networks can be attacked if they use weak passwords or outdated security protocols. Ethical hackers test Wi-Fi networks to make sure they cannot be easily broken into or eavesdropped on.

Example:

An ethical hacker tests a company's Wi-Fi network and finds it still uses the old, weak WEP security standard instead of the much stronger WPA3, making it an easy target.

Real-Life Example:

Public free Wi-Fi networks in cafes and airports are common real-world targets for this exact kind of attack.

18. Cryptography for Ethical Hackers

Explanation:

Cryptography protects data by converting it into a secret, unreadable format. Ethical hackers need to understand encryption and hashing well, both to test how strong a system's cryptography is, and to recognize when it is implemented incorrectly.

Example:

An ethical hacker checks whether a website is still using an old, broken encryption method (like MD5 for passwords) instead of a modern, secure one.

Real-Life Example:

Many past data breaches became far more damaging simply because passwords were stored using weak or outdated hashing methods.

19. Evading Firewalls, IDS, and Honeypots

Explanation:

Firewalls and IDS (Intrusion Detection Systems) try to block or detect attacks. Ethical hackers test whether these defenses can be bypassed (evaded), so companies know if their protection actually works. A Honeypot is a fake, decoy system set up on purpose to trap and study attackers.

Example:

An ethical hacker tests whether sending data in smaller, disguised pieces can slip past a company's firewall without triggering an alert.

Real-Life Example:

Security researchers often set up honeypots on the internet specifically to observe real hacking techniques being used in the wild.

20. Mobile and Cloud Platform Hacking

Explanation:

As more data moves to phones and cloud services, ethical hackers now also test mobile apps (for insecure data storage or weak permissions) and cloud platforms (for misconfigured storage or weak access control).

Example:

An ethical hacker discovers that a company's cloud storage bucket was accidentally left public, allowing anyone on the internet to view private customer files.

Real-Life Example:

Several major real-world data leaks have happened simply because a cloud storage folder was left open to the public by mistake.

★ 21. Tools Used in Ethical Hacking [IMPORTANT TOPIC]

Explanation:

Ethical hackers use specialized tools at different stages of testing, instead of doing everything manually. Knowing these tools well is a core skill in this field.

Key Points:

- Nmap -> scans networks to find open ports and live devices.
- Wireshark -> captures and analyzes network traffic (packet sniffing).
- Metasploit -> a framework used to test and exploit known vulnerabilities.
- Burp Suite -> tests the security of websites and web applications.
- John the Ripper -> tests the strength of passwords by trying to crack them.

Example:

A pen tester uses Nmap to find open ports on a target server, then uses Metasploit to safely test a known weakness on one of those open ports.

Real-Life Example:

Kali Linux is a popular operating system that comes with almost all of these ethical hacking tools already pre-installed.

★ 22. Report Writing and Legal Aspects [IMPORTANT TOPIC]

Explanation:

The final and most important step of any ethical hacking engagement is writing a clear report explaining every weakness found, how serious it is, and how to fix it. Ethical hacking must ALWAYS follow a signed legal agreement that defines exactly what is allowed to be tested.

Key Points:

- Scope of Work -> a document defining exactly what systems can be tested, and what is off-limits.
- A good report includes: the weakness found, how it was found, how serious it is, and how to fix it.
- Without written permission, the exact same actions are considered illegal hacking, not ethical hacking.

Example:

After testing, an ethical hacker submits a report showing a critical login weakness, ranks it as 'High Risk', and recommends the exact fix needed.

Real-Life Example:

In India, hacking without permission is punishable under the IT Act, 2000 — which is exactly why the signed agreement is legally necessary before any testing begins.

 *Note: 'No permission = no ethical hacking' — this single rule is what legally separates a White Hat hacker from a criminal.*